

TRABALHO DE ANÁLISE DE VULNERABILIDADES – NESSUS × NMAP

Aluno: Jonatan Luiz

Professor: Marcio Pohlmann

Data: 11/12/2025



Introdução

Este trabalho apresenta uma análise comparativa de vulnerabilidades identificadas em duas máquinas virtualmente vulneráveis (BeeBox e Mr. Robot), utilizando dois métodos distintos de varredura:

Ferramenta de varredura profissional

Nessus Essentials, executado inicialmente em Docker e posteriormente com versão Trial Pro (Nessus 10).

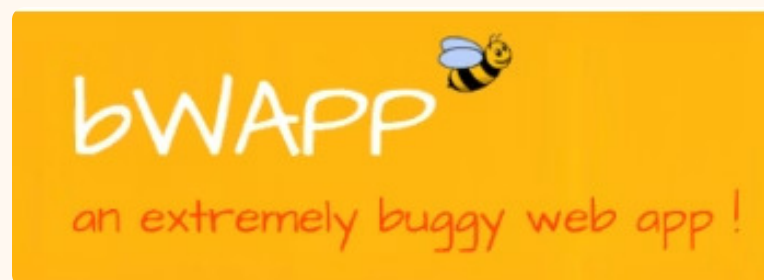
Ferramenta de varredura manual/avançada

Nmap com scripts NSE, incluindo Vulners e Vulscan.

O objetivo é comparar os resultados gerados por:

- uma ferramenta de análise automatizada e baseada em plugins (Nessus);
- uma abordagem de detecção por assinatura e correlação de versões (Nmap).

Ambiente e Ferramentas Utilizadas



Virtual Box



Vmware



Ambiente e Ferramentas Utilizadas

2.1 Máquinas de Análise (Atacantes)

Máquina 1 – Debian + Nessus

- **Hypervisor:** VirtualBox
- **Sistema operacional:** Debian 13
- **Ferramenta:** Nessus Essentials (Docker) e Nessus 10 Trial
- **IP:** 192.168.1.17

Máquina 2 – Kali Linux + Nmap

- **Hypervisor:** VirtualBox
- **Sistema operacional:** Kali Linux
- **Ferramenta:** Nmap + NSE (Vulners e Vulscan)
- **IP:** 192.168.1.5

2.2 Máquinas Alvo

BeeBox

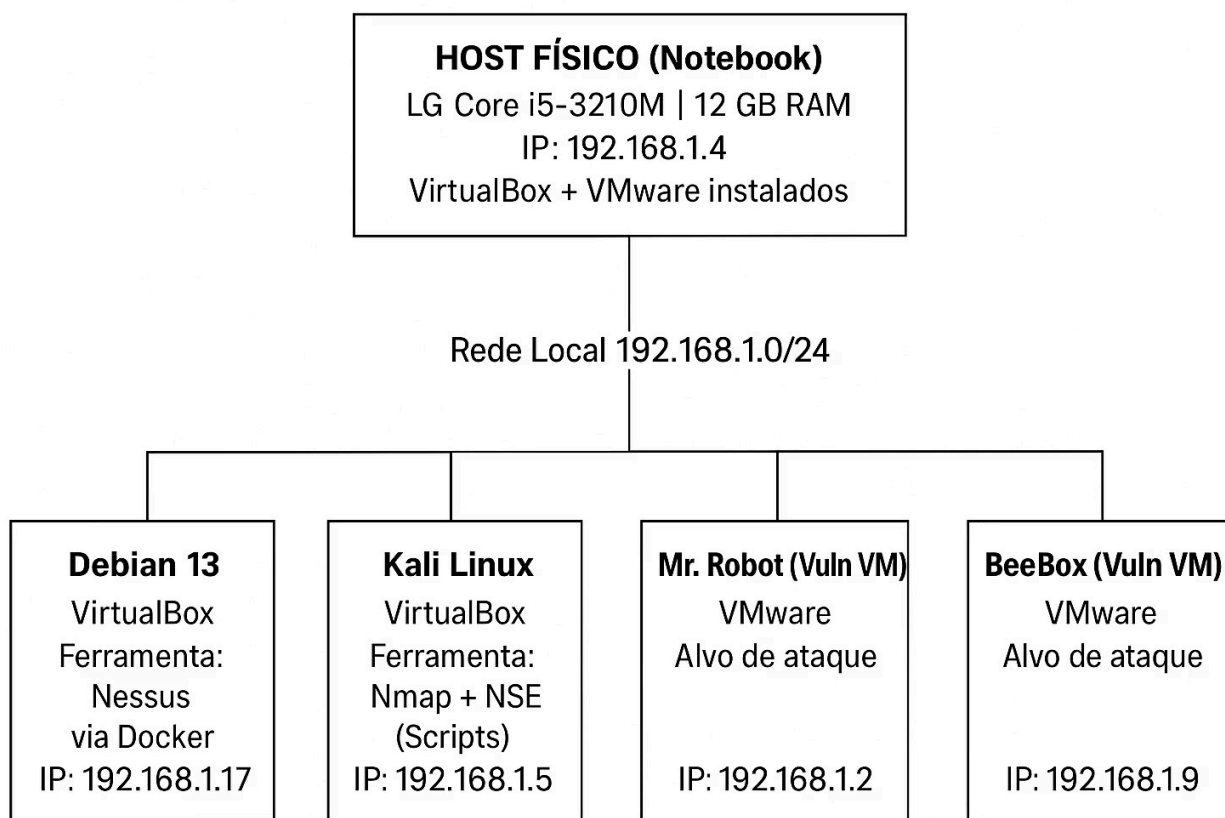
- **Hypervisor:** VMware
- Sistema propositalmente vulnerável com DVWA e serviços desatualizados
- **IP:** 192.168.1.9

Mr. Robot (VulnHub)

- **Hypervisor:** VirtualBox
- Máquina vulnerável baseada na série Mr. Robot
- **IP:** 192.168.1.2

Topologia da Rede

Resumo da Topologia:

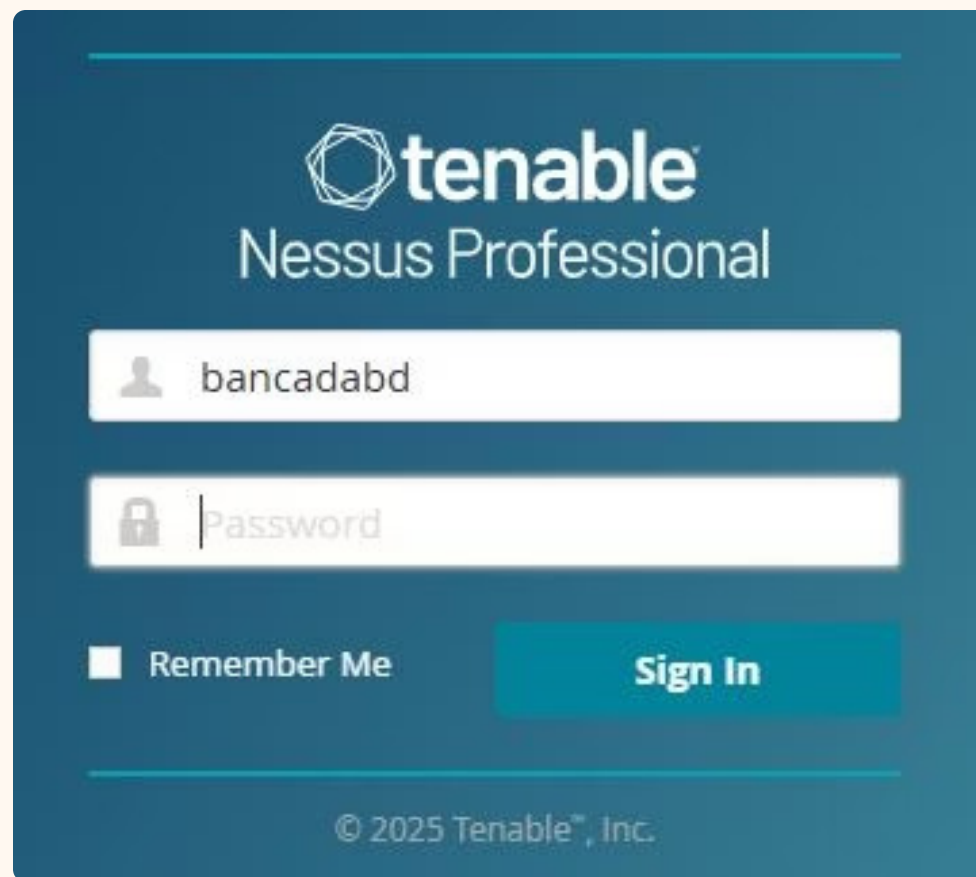


Host Principal:

- Notebook LG Core i5-3210M
- Memória: 12 GB RAM
- IP: 192.168.1.4
- Hypervisores instalados: VirtualBox e VMware

Análise com Nessus versão 10

As máquinas foram escaneadas utilizando Nessus com plugins atualizados, porém com limitações da licença Trial (sem exportação PDF/CSV).



Nessus Professional Version trial

tenable

Nessus Professional

Scans

Settings

SETTINGS

About

Advanced

Proxy Server

Remote Link

SMTP Server

Custom CA

Upgrade Assistant

Password Mgmt

Scanner Health

Debug Logs

Notifications

ACCOUNTS

My Account

About

Overview

License Utilization

Software Update

Plugin Detail Locale

Encryption Password

Events

Feed Status

Request to plugins.nessus.org failed.
[Clear feed status](#)

Nessus Professional Version 10

Version

10.11.0 (#161) LINUX

Licensed Hosts

2 of 32 used

Plugins

Last Updated

December 9 at 2:31 AM

License Expiration

December 16, 2025 [Buy Nessus Professional now](#)

Plugin Set

202512090231

Policy Template Version

202512081656

Activation Code

85XB-QM28-2F47-KANF

Your trial will expire in 5 days, on Dec 16, 2025. To unlock more features and continue using Nessus Professional beyond your Trial, [Purchase Now](#)

Máquinas Alvos

VM vulnerável BeeBox => IP: 192.168.1.9

VM vulnerável Mr Robot => IP: 192.168.1.2

tenable

Nessus Professional

Scans

Settings

?

bancadabd

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Customized Reports

My Scans

Import

New Folder

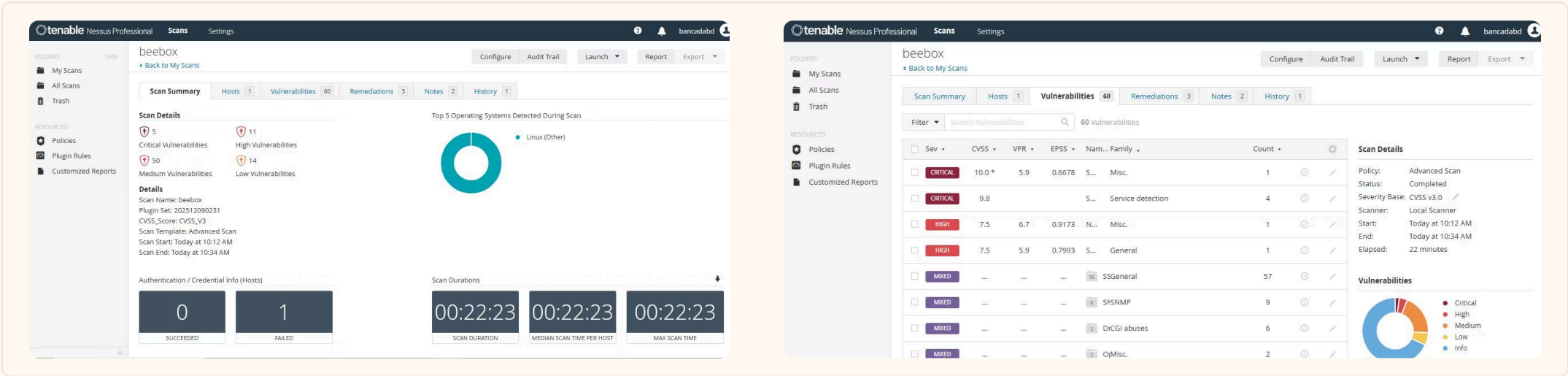
New Scan

Search Scans

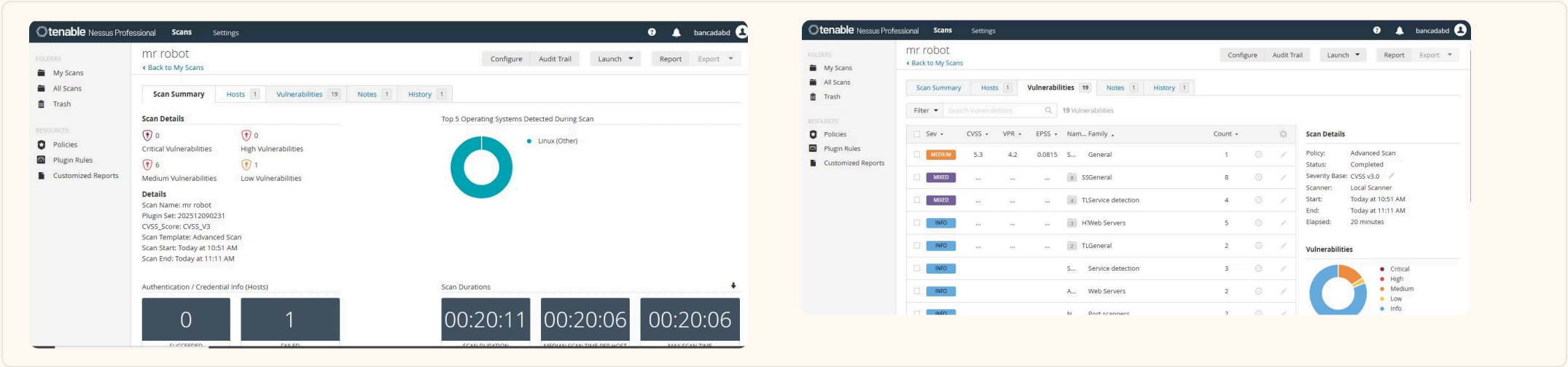
2 Scans

☐	Name	Scan Type	Schedule	Last Scanned		
☐	mr robot	Vulnerability	On Demand	✓ Today at 11:11 AM		
☐	beebox	Vulnerability	On Demand	✓ Today at 10:34 AM		

BeeBox



Mr Robot



4.1 Resultados Gerais

BeeBox – 59 vulnerabilidades detectadas

- **Críticas:** 5
- **Altas:** 3
- **Médias:** diversas
- **Mixed / Informational:** grande volume
 - Web servers
 - CGI abuses
 - SNMP
 - Service Detection

 O relatório do BeeBox é o mais relevante, com falhas reais e exploráveis.

Mr. Robot – 18 vulnerabilidades detectadas

- Nenhuma crítica/alta
- **Médias:** 2
- **Demais entradas são:**
 - Service Detection
 - Web Servers
 - Informational

 Apresenta superfície de ataque limitada.

4.2 Top 10 Vulnerabilidades – BeeBox (Nessus)

- | | | | | | |
|----|---|---|--|---|--|
| 1 | Vulnerabilidade Crítica – CVSS 10.0 (Misc) | 2 | Service Detection alta – CVSS 9.8 (4 entradas) | 3 | Vulnerabilidade Alta – CVSS 7.5 (Misc) |
| 4 | Vulnerabilidade Alta – CVSS 7.5 – Service Detection | 5 | Alta Severidade – CVSS 7.5 – Geral | 6 | CGI Abuses – 6 ocorrências |
| 7 | SNMP Exposures – 9 ocorrências | 8 | Web Servers – 17 ocorrências | 9 | Misc Medium – diversas entradas |
| 10 | SMTP Problems – 2 ocorrências | | | | |

Obs.: Grande parte das detecções envolve identificação de banners e services detection, comuns em sistemas antigos.

4.3 Top 10 Vulnerabilidades – Mr. Robot (Nessus)

- | | | | | | |
|----|---|---|--|---|---|
| 1 | Média – CVSS 5.9 (Geral) | 2 | Média – CVSS 5.3 (Geral) | 3 | Mixed – Service Detection (4 ocorrências) |
| 4 | Web Server Detection (2 ocorrências) | 5 | Web Server Information (5 ocorrências) | 6 | Mixed – Geral (8 ocorrências) |
| 7 | Informational – Service Detection (3 ocorrências) | 8 | Informational – Port Scanner (2 ocorrências) | 9 | Configurações do Apache (1 ocorrência) |
| 10 | Informational – Achados gerais | | | | |

4.4 Observações Importantes sobre o Nessus

- A versão Docker não recebe atualizações de plugins, reduzindo drasticamente a detecção.
- A análise relevante foi realizada com **Nessus 10 Trial Professional**, instalado diretamente no Debian.
- A versão Trial impede exportar relatórios PDF/CSV, mas roda com feed atualizado.

Análise com Nmap (Vulners + Vulscan)

Comandos utilizados – BeeBox

```
nmap -sV --script vulners 192.168.1.9 -oN scan_vulners_bee.txt  
nmap -sV --script=vulscan/vulscan.nse 192.168.1.9 -oN scan_vulscan_bee.txt
```

Comandos utilizados – Mr. Robot

```
nmap -sn 192.168.1.0/24  
nmap -sV --script vulners 192.168.1.2 -oN scan_vulners_mr.txt  
nmap -sV --script=vulscan/vulscan.nse 192.168.1.2 -oN scan_vulscan_mr.txt
```


Análise com Nmap (Vulners + Vulscan)

```

kali@kali: ~
File Actions Edit View Help

└─$ nmap -sV --script vulners 192.168.1.9 -oN scan_vulners_mr.txt

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-10 16:36 EST
Stats: 0:22:39 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.87% done; ETC: 16:58 (0:00:02 remaining)
Nmap scan report for 192.168.1.9
Host is up (0.015s latency).
Not shown: 983 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.3
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
25/tcp    open  smtp         Postfix smtpd
80/tcp    open  http         Apache/2.2.8 ((Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5
with Suhosin-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5 with Suhosin
-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: ITSECgames)
443/tcp   open  ssl/http     Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5
with Suhosin-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5 with Suhosin
-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: ITSECgames)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell?
666/tcp   open  doom?
|_fingerprnt-strings:
|_GenericLines, beast2:

```

[illegible]

Análise com Nmap (Vulners + Vulscan)

```
# Nmap 7.95 scan initiated Sat Nov 22 14:53:28 2025 as: /usr/lib/nmap/nmap --privileged -sV --script=vulscan/vulscan.nse -oN scan_vulscan_bee.txt 192
Nmap scan report for 192.168.1.9
Host is up (0.0071s latency).
Not shown: 983 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.1
| vulscan: VulDB - https://vuldb.com:
| No findings

MITRE CVE - https://cve.mitre.org:
[CVE-2009-0543] ProFTPD Server 1.3.1, with NLS support enabled, allows remote attackers to bypass SQL injection protection mechanisms via invalid,
[CVE-2009-0542] SQL injection vulnerability in ProFTPD Server 1.3.1 through 1.3.2rc2 allows remote attackers to execute arbitrary SQL commands via
[CVE-2008-4242] ProFTPD 1.3.1 interprets long commands from an FTP client as multiple commands, which allows remote attackers to conduct cross-site
[CVE-2006-6563] Stack-based buffer overflow in the pr_ctrls_recv_request function in ctrlis.c in the mod_ctrls module in ProFTPD before 1.3.1rc1 all
[CVE-2012-6095] ProFTPD before 1.3.5rc1, when using the UserOwner directive, allows local users to modify the ownership of arbitrary files via a ra
[CVE-2011-4130] Use-after-free vulnerability in the Response API in ProFTPD before 1.3.3g allows remote authenticated users to execute arbitrary co
[CVE-2011-1137] Integer overflow in the mod_sftp (aka SFTP) module in ProFTPD 1.3.3d and earlier allows remote attackers to cause a denial of servi
[CVE-2010-4652] Heap-based buffer overflow in the sql_prepare_where function (contrib/mod_sql.c) in ProFTPD before 1.3.3d, when mod_sql is enabled,
[CVE-2010-4221] Multiple stack-based buffer overflows in the pr_netio_telnet_gets function in netio.c in ProFTPD before 1.3.3c allow remote attacke
[CVE-2010-3867] Multiple directory traversal vulnerabilities in the mod_site_misc module in ProFTPD before 1.3.3c allow remote authenticated users
[CVE-2009-3639] The mod_tls module in ProFTPD before 1.3.2b, and 1.3.3 before 1.3.3rc2, when the dNSNameRequired TLS option is enabled, does not pr
[CVE-2008-7265] The pr_data_xfer function in ProFTPD before 1.3.2rc3 allows remote authenticated users to cause a denial of service (CPU consumptio
[CVE-2006-6171] ** DISPUTED ** ProFTPD 1.3.0a and earlier does not properly set the buffer size limit when CommandBufferSize is specified in the c
[CVE-2006-6170] Buffer overflow in the tls_x509_name_online function in the mod_tls module, as used in ProFTPD 1.3.0a and earlier, and possibly ot
[CVE-2006-5815] Stack-based buffer overflow in the sreplac function in ProFTPD 1.3.0 and earlier allows remote attackers, probably authenticated,
[CVE-2005-4816] Buffer overflow in mod_radius in ProFTPD before 1.3.0rc2 allows remote attackers to cause a denial of service (crash) and possibly
[CVE-2005-2390] Multiple format string vulnerabilities in ProFTPD before 1.3.0rc2 allow attackers to cause a denial of service or obtain sensitive
[CVE-2004-0529] The modified suexec program in cPanel, when configured for mod_php and compiled for Apache 1.3.31 and earlier without mod_php suexec
```

```
# Nmap 7.95 scan initiated Sat Nov 22 14:53:28 2025 as: /usr/lib/nmap/nmap --privileged -sV --script=vulscan/vulscan.nse -oN scan_vulscan_bee.txt 192
Nmap scan report for 192.168.1.9
Host is up (0.0071s latency).
Not shown: 983 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.1
| vulscan: VulDB - https://vuldb.com:
| No findings

MITRE CVE - https://cve.mitre.org:
[CVE-2009-0543] ProFTPD Server 1.3.1, with NLS support enabled, allows remote attackers to bypass SQL injection protection mechanisms via invalid,
[CVE-2009-0542] SQL injection vulnerability in ProFTPD Server 1.3.1 through 1.3.2rc2 allows remote attackers to execute arbitrary SQL commands via
[CVE-2008-4242] ProFTPD 1.3.1 interprets long commands from an FTP client as multiple commands, which allows remote attackers to conduct cross-site
[CVE-2006-6563] Stack-based buffer overflow in the pr_ctrls_recv_request function in ctrlis.c in the mod_ctrls module in ProFTPD before 1.3.1rc1 all
[CVE-2012-6095] ProFTPD before 1.3.5rc1, when using the UserOwner directive, allows local users to modify the ownership of arbitrary files via a ra
[CVE-2011-4130] Use-after-free vulnerability in the Response API in ProFTPD before 1.3.3g allows remote authenticated users to execute arbitrary co
[CVE-2011-1137] Integer overflow in the mod_sftp (aka SFTP) module in ProFTPD 1.3.3d and earlier allows remote attackers to cause a denial of servi
[CVE-2010-4652] Heap-based buffer overflow in the sql_prepare_where function (contrib/mod_sql.c) in ProFTPD before 1.3.3d, when mod_sql is enabled,
[CVE-2010-4221] Multiple stack-based buffer overflows in the pr_netio_telnet_gets function in netio.c in ProFTPD before 1.3.3c allow remote attacke
[CVE-2010-3867] Multiple directory traversal vulnerabilities in the mod_site_misc module in ProFTPD before 1.3.3c allow remote authenticated users
[CVE-2009-3639] The mod_tls module in ProFTPD before 1.3.2b, and 1.3.3 before 1.3.3rc2, when the dNSNameRequired TLS option is enabled, does not pr
[CVE-2008-7265] The pr_data_xfer function in ProFTPD before 1.3.2rc3 allows remote authenticated users to cause a denial of service (CPU consumptio
[CVE-2006-6171] ** DISPUTED ** ProFTPD 1.3.0a and earlier does not properly set the buffer size limit when CommandBufferSize is specified in the c
[CVE-2006-6170] Buffer overflow in the tls_x509_name_online function in the mod_tls module, as used in ProFTPD 1.3.0a and earlier, and possibly ot
[CVE-2006-5815] Stack-based buffer overflow in the sreplac function in ProFTPD 1.3.0 and earlier allows remote attackers, probably authenticated,
[CVE-2005-4816] Buffer overflow in mod_radius in ProFTPD before 1.3.0rc2 allows remote attackers to cause a denial of service (crash) and possibly
[CVE-2005-2390] Multiple format string vulnerabilities in ProFTPD before 1.3.0rc2 allow attackers to cause a denial of service or obtain sensitive
[CVE-2004-0529] The modified suexec program in cPanel, when configured for mod_php and compiled for Apache 1.3.31 and earlier without mod_php suexec
```

Resultados – Nmap

7.1 BeeBox – Vulners

- Apache 2.2.8 / OpenSSL 0.9.8g → múltiplas CVEs graves
- Samba 3.x → Heap-Based Buffer Overflow (CVE-2012-0870)
- OpenSSH 4.7p1 → dezenas de CVEs
- PHP 5.2.4 + MySQL 5.0 → vulnerabilidades críticas
- nginx 1.4.0 e Lighttpd 1.4 → falhas adicionais

7.2 BeeBox – Vulscan

- Amplia drasticamente a quantidade de CVEs detectadas
- Vulnerabilidades em módulos Apache:
 - mod_ssl
 - mod_rewrite
 - mod_info
 - mod_status
- Associações adicionais a serviços antigos de SSH, PHP e MySQL

Resultados – Nmap

7.3 Mr. Robot – Vulners

- Poucas vulnerabilidades devido à detecção incompleta da versão do Apache
- Resultado limitado

7.4 Mr. Robot – Vulscan

- Possíveis RCE associadas ao Apache Struts (ex.: CVE-2013-2251)
- Falhas relacionadas a:
 - mod_security
 - mod_dav_svn
 - mod_rewrite
- CVEs associadas a ActiveMQ, Tomcat, CXF etc. (muitas irrelevantes ou falsos positivos)

8. Mitigações Recomendadas

Atualizar todos os serviços e pacotes vulneráveis identificados, como:

As recomendações do Nessus devem ser priorizadas por criticidade (CVSS/VPR).

- · OpenSSL
- · Samba
- · nginx
- · Apache
- · PHP
- · MySQL
- · SSH

Tabela de comparação - BeeBox

Serviço / Sistema	Porta	Severidade	Nessus	Vulners	Vulscan
Apache 2.2.8	80/443	Crítica	✓	✓	✓ (muitas)
PHP 5.2.x	80/443	Crítica	✓	✓	✓
OpenSSL 0.9.8g	443	Alta	✓	✓	✓
OpenSSH 4.7p1	22	Alta	✓	✓	✓ +200 CVEs
Samba 3.x	139/445	Alta	✓	✓	✓
MySQL 5.0.96	3306	Média	✓	Detectado	Pouco
nginx 1.4.0	8080	Média	✓	✓	✓
lighttpd 1.4	9080	Média	✓	✓	✓
Serviços legados rsh/login	512-514	Alta	✓	Detectado	—

Mr. Robot

Serviço	Porta	Nessus	Vulners	Vulscan
Apache HTTP	80	Média	—	✓
HTTPS / SSL	443	Info	—	✓
Outros	—	Sem achados	—	Falsos positivos

9. Conclusão Final

- A **BeeBox** é extremamente vulnerável, apresentando dezenas de falhas exploráveis em praticamente todos os serviços.
- A **Mr. Robot** possui superfície de ataque menor, com falhas de impacto limitado.
- **Nmap (Vulners/Vulscan)** detecta muito mais vulnerabilidades
- **Vulners** fornece CVEs precisas.
- **Vulscan** fornece listas amplas, porém exige filtragem para evitar falsos positivos.